

BÁO CÁO PHÂN TÍCH & THIẾT KẾ
HỆ THỐNG THÔNG TIN

TECHHUB PC

Website thương mại điện tử kinh doanh linh kiện máy tính

*Use Case • User Story • Requirements • Database Domain
System Design • RBAC/JWT • Threat Model • Traceability*

Lớp:

Nhóm/Sinh viên:

Giảng viên:

Hà Nội, tháng 08 năm 2026

THÔNG TIN KIỂM SOÁT TÀI LIỆU

Thuộc tính	Nội dung
Tên hệ thống	TechHub PC - Website thương mại điện tử linh kiện máy tính
Loại tài liệu	Hồ sơ phân tích và thiết kế hệ thống thông tin
Phiên bản	1.0 - Thiết kế mục tiêu cho phiên bản đầu
Ngày lập	21/08/2026
Trạng thái	Dùng để review và triển khai; cần bổ sung thông tin lớp/nhóm trước khi nộp
Quy tắc tên file nộp	TenLop_TenNhom_TenDeTai.docx

Trạng thái triển khai Frontend đã hoàn thành nền Vite/React, Router, Tailwind và Axios. Các module nghiệp vụ, backend .NET 10 và PostgreSQL trong tài liệu là thiết kế mục tiêu sẽ được triển khai theo lộ trình; tài liệu không tuyên bố các phần đó đã hoàn thành.

MỤC LỤC

THÔNG TIN KIỂM SOÁT TÀI LIỆU..... 2

MỤC LỤC..... 3

TÓM TẮT ĐIỀU HÀNH..... 4

1. BỐI CẢNH, MỤC TIÊU VÀ PHẠM VI 4

2. TÁC NHÂN VÀ USE CASE 6

3. USER STORY VÀ ACCEPTANCE CRITERIA 9

4. YÊU CẦU CHỨC NĂNG VÀ PHI CHỨC NĂNG 10

5. DOMAIN MODEL VÀ THIẾT KẾ DỮ LIỆU 11

6. THIẾT KẾ HỆ THỐNG..... 14

7. API CONTRACT 18

8. BUSINESS RULES VÀ STATE MACHINE..... 20

9. TRADE-OFF VÀ ARCHITECTURE DECISION RECORDS 21

10. THREAT MODEL, RBAC VÀ JWT..... 22

11. KẾ HOẠCH KIỂM THỬ..... 24

12. TRACEABILITY MATRIX..... 25

13. KHẢ NĂNG MỞ RỘNG VÀ VẬN HÀNH..... 26

14. THIẾT KẾ GIAO DIỆN VÀ ÁNH XẠ CHỨC NĂNG..... 27

15. KẾT LUẬN..... 31

TÀI LIỆU THAM KHẢO VÀ CÔNG CỤ..... 32

PHỤ LỤC A - GLOSSARY 32

TÓM TẮT ĐIỀU HÀNH

TechHub PC là hệ thống thương mại điện tử chuyên kinh doanh linh kiện máy tính. Hệ thống hỗ trợ ba nhóm tác nhân: Guest, Customer và Admin; bao phủ từ tìm kiếm sản phẩm, giỏ hàng, checkout đến quản lý kho, đơn hàng, đánh giá và thống kê.

Thiết kế chọn kiến trúc modular monolith gồm React SPA, ASP.NET Core Web API .NET 10 và PostgreSQL. Cách tiếp cận này giữ chi phí triển khai phù hợp kế hoạch học kỳ, đồng thời duy trì ranh giới module để có thể mở rộng khi tải hoặc đội phát triển tăng.

Mục tiêu thiết kế Tạo một hồ sơ đủ chi tiết để người phát triển có thể triển khai mà không phải hỏi lại các quyết định quan trọng; mọi luồng ưu tiên đều truy vết được từ mục tiêu, yêu cầu, dữ liệu, API đến kiểm thử.

Cấu trúc hồ sơ theo rubric

Nhóm chấm	Phần trong tài liệu	Bảng chứng chính
Phân tích & thiết kế	Chương 1-8	Goal, Use Case, User Story/AC, FR/NFR, ERD, context, module, sequence, API
Trade-off & ADR	Chương 9	Bốn quyết định có options, rationale, consequences và trigger xem xét lại
Security	Chương 10	Trust boundary, threat rating, RBAC matrix, JWT flow, negative tests
Tài liệu & truy vết	Chương 11-12	Test catalog, RTM Goal→UC→FR/NFR→Entity/API→Test
Mở rộng & vận hành	Chương 13	Tải giả định, index/cache/pagination, health/log/audit, debt và roadmap

1. BỐI CẢNH, MỤC TIÊU VÀ PHẠM VI

1.1. Bối cảnh và vấn đề

Cửa hàng linh kiện máy tính cần một kênh bán hàng trực tuyến tập trung. Nếu quản lý sản phẩm, đơn hàng và tồn kho bằng các bảng rời, dữ liệu dễ lệch, khó truy nguồn xuất/nhập và có nguy cơ nhận đơn vượt tồn kho. TechHub PC giải quyết vấn đề này bằng một luồng xuyên suốt từ catalog đến vận hành sau bán.

1.2. Mục tiêu nghiệp vụ

ID	Mục tiêu
G-01	Khách tìm được sản phẩm phù hợp theo từ khóa, danh mục, giá và tiêu chí sắp xếp.
G-02	Customer đặt hàng an toàn; giá và tồn kho được backend xác nhận tại thời điểm tạo đơn.
G-03	Customer theo dõi lịch sử, trạng thái và chỉ đánh giá sản phẩm đã mua trong đơn hoàn thành.

ID	Mục tiêu
G-04	Admin quản lý danh mục, sản phẩm, người dùng, kho và đơn hàng theo đúng quyền.
G-05	Dữ liệu kho có lịch sử biến động, cảnh báo tồn thấp và không bị âm do cạnh tranh đồng thời.
G-06	Quản trị viên xem được doanh thu, đơn hàng, sản phẩm bán chạy và hàng sắp hết theo thời gian.

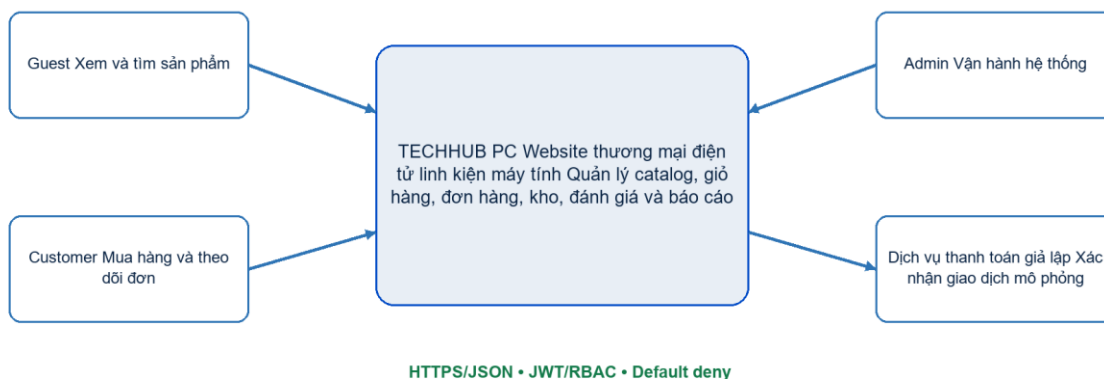
1.3. Phạm vi phiên bản đầu

Trong phạm vi	Ngoài phạm vi phiên bản đầu
Tài khoản Customer/Admin và RBAC permission-based	Build PC và kiểm tra tương thích linh kiện
Catalog, tìm kiếm, lọc, sắp xếp, chi tiết sản phẩm	Chatbot/AI tư vấn và gợi ý thông minh
Giỏ hàng, checkout, COD và thanh toán giả lập	Voucher/khuyến mãi phức tạp
Đơn hàng, trạng thái, hủy theo điều kiện	Thanh toán trực tuyến bằng tiền thật
Kho, nhập/xuất, lịch sử, cảnh báo tồn thấp	Tích hợp hãng vận chuyển thực tế
Đánh giá đã xác minh và thống kê quản trị	Microservices, message broker và search engine riêng

1.4. Giả định và ràng buộc

- Kế hoạch triển khai cốt lõi trong khoảng 6 tuần bởi một nhóm sinh viên nhỏ.
- Thanh toán online được mô phỏng; COD là phương thức chính của phiên bản đầu.
- Sản phẩm có một mức tồn có thể bán; chưa tách nhiều kho vật lý.
- Frontend và API có thể chạy khác origin trong môi trường phát triển; CORS chỉ cho phép origin đã cấu hình.
- Mọi giá trị tiền dùng decimal tại backend và numeric/decimal trong PostgreSQL; không dùng float.

System Context - phạm vi và tác nhân



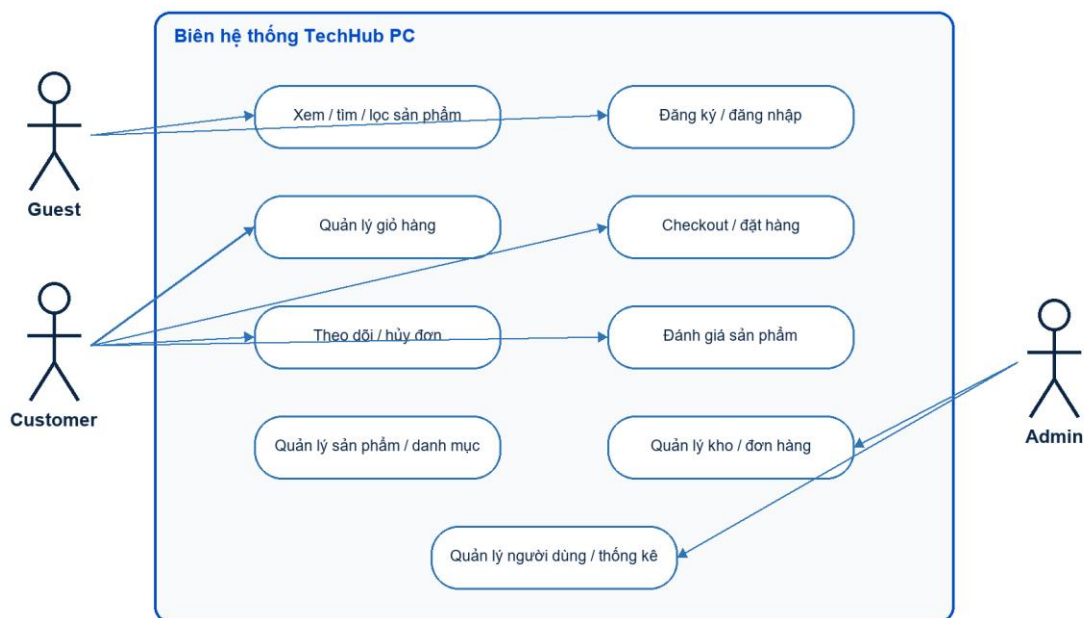
Hình 1. System Context và phạm vi tương tác của TechHub PC

2. TÁC NHÂN VÀ USE CASE

2.1. Tác nhân

Actor	Mục tiêu	Quyền tiêu biểu
Guest	Khám phá catalog và trở thành khách hàng	product.read, category.read, review.read, auth.register, auth.login
Customer	Mua hàng và quản lý thông tin của chính mình	cart.*, order.create, order.self.read, order.self.cancel, review.create, profile.self.update
Admin	Vận hành cửa hàng	user.manage, category.*, product.*, inventory.*, order.manage, review.moderate, report.read

Use Case tổng thể - TechHub PC



Hình 2. Use Case Diagram tổng thể và biên hệ thống

2.2. Danh mục Use Case

ID	Tên	Actor	Kết quả
UC-01	Tra cứu sản phẩm	Guest/Customer	Tìm kiếm, lọc, sắp xếp và xem chi tiết
UC-02	Đăng ký/đăng nhập	Guest	Tạo phiên xác thực và nạp quyền
UC-03	Quản lý giỏ hàng	Customer	Thêm/xóa/đổi số lượng, xem tổng tạm tính
UC-04	Checkout và đặt hàng	Customer	Kiểm tra giá/tồn, tạo Order và OrderItem
UC-05	Theo dõi/hủy đơn	Customer	Chỉ thao tác trên đơn của chính mình
UC-06	Đánh giá sản phẩm	Customer	Chỉ review sản phẩm đã mua và hoàn thành
UC-07	Quản lý sản phẩm	Admin	CRUD/ẩn sản phẩm và thông số
UC-08	Quản lý kho	Admin	Nhập/xuất, lịch sử và cảnh báo
UC-09	Xử lý đơn hàng	Admin	Cập nhật trạng thái theo state machine
UC-10	Quản lý người dùng	Admin	Khóa/mở và gán role
UC-11	Xem thống kê	Admin	Doanh thu, đơn, top sản phẩm, tồn thấp

2.3. UC-01 - Tra cứu sản phẩm

Tiền điều kiện: Guest hoặc Customer cần tìm sản phẩm phù hợp.

Luồng chính:

1. Người dùng nhập từ khóa hoặc chọn danh mục/bộ lọc.
2. Frontend gửi GET /api/products với query và phân trang.
3. API kiểm tra giới hạn page/pageSize, truy vấn sản phẩm đang hiển thị và trả tổng số kết quả.
4. Người dùng mở trang chi tiết để xem ảnh, giá, tồn và thông số.

Luồng thay thế/lỗi:

- Không có kết quả: trả danh sách rỗng và gợi ý bỏ bớt bộ lọc.
- Tham số không hợp lệ: 400 ProblemDetails.
- Sản phẩm đã ẩn: 404 hoặc không xuất hiện trong danh sách công khai.

2.4. UC-04 - Checkout và đặt hàng

Tiền điều kiện: Customer đã đăng nhập, giỏ hàng có ít nhất một sản phẩm.

Luồng chính:

5. Customer nhập người nhận, số điện thoại, địa chỉ, ghi chú và phương thức COD/giả lập.
6. Frontend gửi POST /api/orders cùng các productId và quantity.
7. Backend xác thực quyền order.create; đọc lại sản phẩm, giá và tồn kho trong transaction.
8. Backend tạo Order/OrderItems, snapshot giá/địa chỉ, trừ tồn và ghi biến động kho.
9. API trả 201 Created và mã đơn; frontend hiển thị xác nhận.

Luồng thay thế/lỗi:

- JWT thiếu/hết hạn: 401.
- Không có permission: 403.
- Giá thay đổi hoặc không đủ tồn: 409, không tạo đơn và không trừ kho.
- Một sản phẩm bị ẩn: 409 và yêu cầu cập nhật giỏ.

2.5. UC-08 - Nhập kho

Tiền điều kiện: Admin có permission inventory.import.

Luồng chính:

10. Admin chọn sản phẩm, nhập số lượng dương và ghi chú/chứng từ.
11. API kiểm tra sản phẩm và dữ liệu.
12. Trong transaction, hệ thống tạo InventoryTransaction loại IMPORT và cộng tồn.
13. Hệ thống ghi AuditLog và trả số tồn mới.

Luồng thay thế/lỗi:

- Không đủ quyền: 403.
- Sản phẩm không tồn tại: 404.
- Số lượng bằng 0/âm: 400.
- Lỗi transaction: rollback toàn bộ.

2.6. UC-09 - Cập nhật trạng thái đơn

Tiền điều kiện: Admin có permission order.manage và đơn tồn tại.

Luồng chính:

14. Admin mở chi tiết đơn.
15. Chọn trạng thái kế tiếp hợp lệ.
16. API kiểm tra state transition, cập nhật và ghi audit.
17. Customer nhìn thấy trạng thái mới trong lịch sử đơn.

Luồng thay thế/lỗi:

- Chuyển trạng thái ngược hoặc bỏ qua bước không cho phép: 409.
- Đơn của trạng thái cuối Completed/Cancelled không được sửa: 409.

3. USER STORY VÀ ACCEPTANCE CRITERIA

ID	Với vai trò	Tôi muốn	Để	UC
US-01	Guest	tìm và lọc sản phẩm	nhANH chóng chọn linh kiện phù hợp	UC-01
US-02	Customer	đặt hàng từ giỏ	hoàn tất mua hàng với giá và tồn chính xác	UC-04
US-03	Customer	xem đơn của mình	theo dõi quá trình xử lý	UC-05
US-04	Customer	hủy đơn Pending	dừng đơn trước khi cửa hàng xử lý	UC-05
US-05	Customer	đánh giá sản phẩm đã mua	chia sẻ trải nghiệm đáng tin cậy	UC-06
US-06	Admin	quản lý sản phẩm và danh mục	catalog luôn chính xác	UC-07
US-07	Admin	nhập/xuất và xem lịch sử kho	biết nguyên nhân mỗi biến động tồn	UC-08
US-08	Admin	xử lý trạng thái đơn	vận hành đúng quy trình	UC-09
US-09	Admin	khóa tài khoản vi phạm	ngăn truy cập nhưng vẫn bảo toàn lịch sử	UC-10
US-10	Admin	xem báo cáo theo thời gian	đánh giá hoạt động kinh doanh	UC-11

3.1. Acceptance Criteria ưu tiên

ID	US	Given / When / Then
AC-01	US-01	Given catalog có sản phẩm đang hiển thị; When tìm theo tên/SKU và lọc danh mục; Then kết quả đúng, có total và phân trang.
AC-02	US-02	Given JWT hợp lệ và đủ tồn; When đặt hàng; Then API trả 201, snapshot giá, trừ tồn và tạo lịch sử kho trong cùng transaction.
AC-03	US-02	Given số lượng vượt tồn; When đặt hàng; Then trả 409, không sinh Order và tồn kho không thay đổi.
AC-04	US-03	Given Customer A; When truy cập orderId của Customer B; Then trả 403/404 và không lộ dữ liệu đơn.

ID	US	Given / When / Then
AC-05	US-04	Given đơn Pending thuộc Customer; When hủy; Then trạng thái thành Cancelled và hoàn tồn nếu đã trừ theo chính sách.
AC-06	US-05	Given đơn Completed có sản phẩm; When gửi rating 1..5; Then tạo review; nếu chưa mua thì trả 403.
AC-07	US-07	Given Admin có inventory.import; When nhập số lượng dương; Then tồn tăng đúng và có transaction/audit log.
AC-08	US-08	Given đơn Confirmed; When chuyển Shipping bỏ qua Preparing; Then trả 409 và trạng thái không đổi.
AC-09	US-09	Given tài khoản bị khóa; When đăng nhập hoặc refresh; Then từ chối truy cập và ghi sự kiện bảo mật.
AC-10	US-10	Given khoảng ngày hợp lệ; When xem thống kê; Then tổng doanh thu chỉ tính đơn Completed và khớp chi tiết.

4. YÊU CẦU CHỨC NĂNG VÀ PHI CHỨC NĂNG

4.1. Functional Requirements (FR)

ID	Yêu cầu
FR-AUTH-01	Cho phép đăng ký Customer bằng email duy nhất và mật khẩu đạt chính sách.
FR-AUTH-02	Đăng nhập trả phiên xác thực; tài khoản khóa không được đăng nhập/refresh.
FR-AUTH-03	Customer xem/cập nhật hồ sơ và đổi mật khẩu của chính mình.
FR-RBAC-01	Backend ánh xạ User-Role-Permission và kiểm tra permission tại endpoint/service.
FR-RBAC-02	Mặc định từ chối endpoint bảo vệ khi không có policy/permission phù hợp.
FR-CAT-01	Guest xem danh mục và sản phẩm đang hoạt động.
FR-CAT-02	Tìm, lọc, sắp xếp và phân trang sản phẩm.
FR-CAT-03	Admin thêm/sửa/ẩn sản phẩm, ảnh và thông số kỹ thuật.
FR-CART-01	Customer thêm/xóa/đổi số lượng và xem tổng tạm tính.
FR-ORDER-01	Backend kiểm tra lại giá, trạng thái và tồn trước khi tạo đơn.
FR-ORDER-02	OrderItem lưu tên/SKU/giá snapshot tại thời điểm đặt.
FR-ORDER-03	Customer chỉ xem và hủy đơn thuộc chính mình khi trạng thái cho phép.
FR-ORDER-04	Admin cập nhật trạng thái theo Pending→Confirmed→Preparing→Shipping→Completed hoặc Cancelled.
FR-INV-01	Nhập/xuất kho tạo bản ghi lịch sử bất biến và cập nhật tồn trong transaction.
FR-INV-02	Không cho phép tồn âm; cảnh báo khi tồn ≤ ngưỡng cấu hình.
FR-REV-01	Chỉ Customer có OrderItem Completed được đánh giá 1-5 sao.
FR-REV-02	Admin ẩn/hiện review và ghi lý do kiểm duyệt.
FR-REPORT-01	Thống kê doanh thu, số đơn, top sản phẩm và tồn thấp theo ngày/tháng/năm.

ID	Yêu cầu
FR-AUDIT-01	Ghi audit cho thay đổi quyền, khóa tài khoản, kho, sản phẩm và trạng thái đơn.

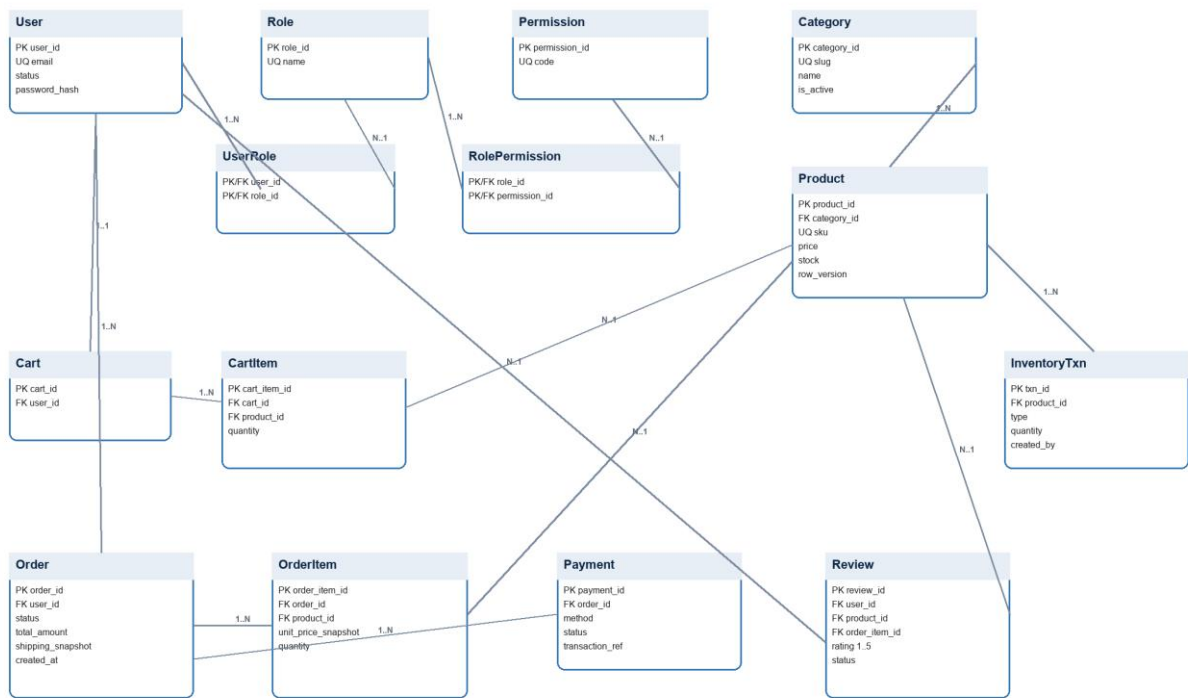
4.2. Non-Functional Requirements (NFR)

ID	Nhóm	Chỉ số kiểm chứng
NFR-PERF-01	Hiệu năng	p95 GET catalog/chi tiết ≤ 2 giây với 10.000 sản phẩm, 50 người dùng đồng thời trên môi trường kiểm thử chuẩn.
NFR-PERF-02	Hiệu năng	p95 tạo đơn ≤ 3 giây; pageSize mặc định 20 và tối đa 100.
NFR-SEC-01	Bảo mật	100% endpoint quản trị yêu cầu JWT hợp lệ và permission; test 401/403/cross-user bắt buộc.
NFR-SEC-02	Bảo mật	Access token 15 phút; refresh token tối đa 7 ngày, xoay vòng và thu hồi khi đổi mật khẩu/khóa tài khoản.
NFR-DATA-01	Toàn vẹn	Tạo đơn và trừ kho là atomic; không tồn âm trong kiểm thử cạnh tranh.
NFR-REL-01	Tin cậy	Lỗi nghiệp vụ trả ProblemDetails có traceId; không trả stack trace ở production.
NFR-OPS-01	Vận hành	Có /health/live và /health/ready; structured log chứa timestamp, level, traceId và route.
NFR-MAINT-01	Bảo trì	Module nghiệp vụ tách rời; service/domain quan trọng có unit test, mục tiêu coverage ≥ 70%.
NFR-UX-01	Trải nghiệm	Giao diện responsive từ 360px; trạng thái loading, empty, validation và lỗi API hiển thị rõ.
NFR-BACKUP-01	Khôi phục	Sao lưu PostgreSQL hằng ngày ở môi trường triển khai; diễn tập restore trước nghiệm thu.

5. DOMAIN MODEL VÀ THIẾT KẾ DỮ LIỆU

Mô hình dữ liệu tách định danh, phân quyền, catalog, giỏ hàng, đơn hàng, kho và đánh giá. Các snapshot trên đơn đảm bảo lịch sử không thay đổi khi tên hoặc giá sản phẩm được cập nhật sau này.

ERD rút gọn - khóa và quan hệ cốt lõi



PK: khóa chính • FK: khóa ngoại • UQ: duy nhất • Giá và địa chỉ được snapshot tại thời điểm đặt hàng

Hình 3. ERD rút gọn, cardinality và các khóa quan trọng

5.1. Domain object/entity

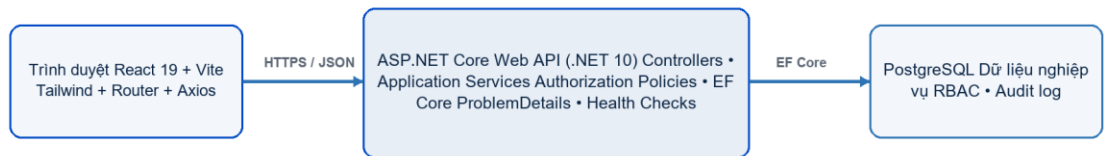
Nhóm entity	Trách nhiệm
User, Role, Permission	Danh tính, trạng thái, role và permission resource.action.
Category, Product	Catalog, SKU, giá, tồn, trạng thái hiển thị và concurrency token.
Cart, CartItem	Giỏ hiện hành; dữ liệu tạm tính, không phải nguồn giá cuối cùng.
Order, OrderItem	Giao dịch mua và snapshot giá/tên/SKU/địa chỉ.
InventoryTransaction	Sổ biến động IMPORT, EXPORT, ORDER, CANCEL_ADJUSTMENT; không sửa/xóa vật lý.
Payment	COD hoặc SIMULATED; không lưu dữ liệu thẻ.
Review	Rating, nội dung, trạng thái moderation và bằng chứng OrderItem.
AuditLog	Ai, hành động, resource, resourceId, thời điểm, traceId và thay đổi quan trọng.

5.2. Constraint và index quan trọng

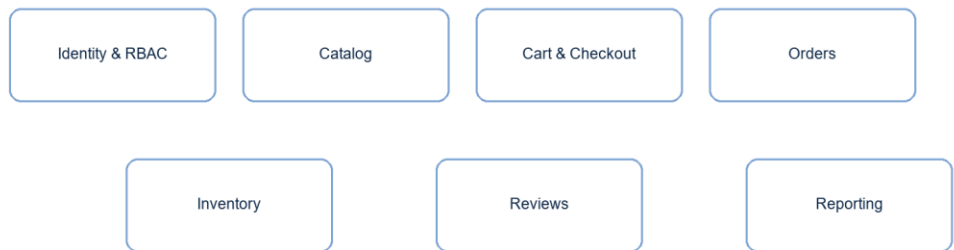
Bảng	Constraint	Index
User	UNIQUE(lower(email)); status ∈ ACTIVE, LOCKED	idx_user_status
Permission	UNIQUE(code), mẫu resource.action	uq_permission_code
Product	UNIQUE(sku); price ≥ 0; stock ≥ 0	idx_product_category_active; GIN/trigram cho search khi cần
CartItem	UNIQUE(cart_id, product_id); quantity > 0	idx_cartitem_cart
Order	status theo enum; total_amount ≥ 0	idx_order_user_created; idx_order_status_created
OrderItem	quantity > 0; unit_price_snapshot ≥ 0	idx_orderitem_order; idx_orderitem_product
InventoryTransaction	quantity_delta ≠ 0; lịch sử bất biến	idx_inventory_product_created
Review	rating BETWEEN 1 AND 5; UNIQUE(user_id, order_item_id)	idx_review_product_status
RefreshToken	UNIQUE(token_hash); expires_at > created_at	idx_refresh_user_expires
AuditLog	append-only	idx_audit_resource_created; idx_audit_actor_created

6. THIẾT KẾ HỆ THỐNG

Container / Module - kiến trúc mục tiêu



Các module nghiệp vụ trong modular monolith



Ranh giới module rõ; triển khai một API để phù hợp phạm vi 6 tuần.

Hình 4. Container và module của kiến trúc modular monolith

6.1. Công nghệ mục tiêu

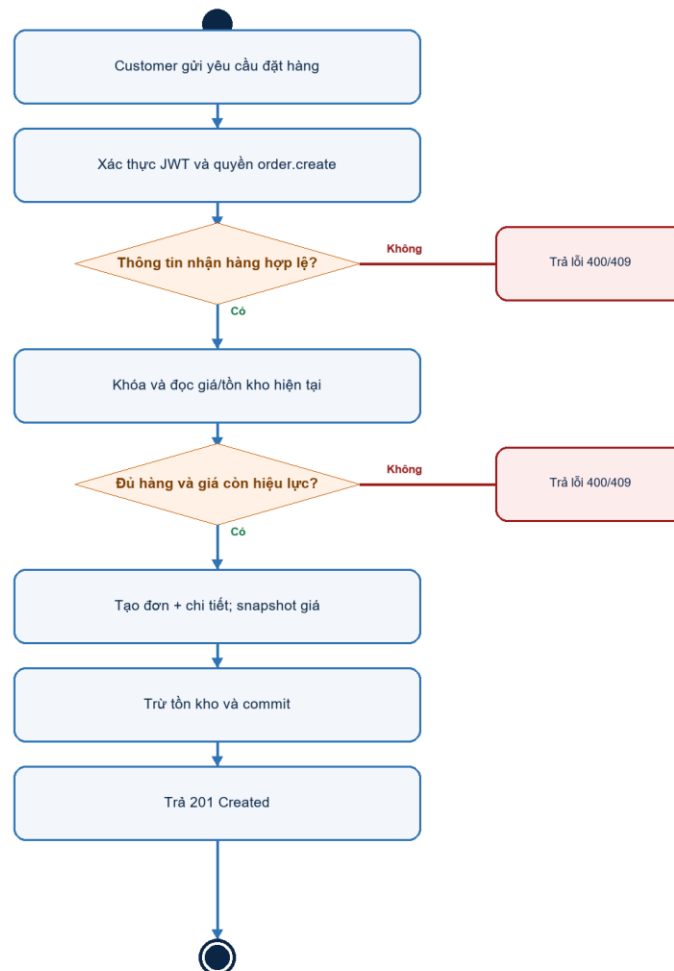
Lớp	Công nghệ	Trách nhiệm
Frontend	React 19, Vite 8, Tailwind CSS 4, React Router 7, Axios	Giao diện SPA, state UI, route, validation sơ bộ và gọi API.
Backend	ASP.NET Core Web API .NET 10, EF Core	Nghiệp vụ, validation quyết định, RBAC/JWT, transaction và API contract.
Database	PostgreSQL	Dữ liệu quan hệ, constraint, index, transaction và audit.
Tài liệu API	OpenAPI/Swagger	Mô tả endpoint, schema, status code và hỗ trợ kiểm thử.
UI prototype	Stitch export chỉ làm tài liệu tham chiếu	Không đưa demo_template vào production hoặc Git; triển khai lại thành component React.

6.2. Quy tắc phụ thuộc module

- Controller chỉ nhận/trả DTO và gọi application service; không chứa truy vấn nghiệp vụ dài.
- Mỗi module sở hữu service, DTO, validation và repository/query liên quan; không truy cập vòng giữa module.
- Authorization kiểm tra tại endpoint và kiểm tra sở hữu resource tại service; frontend chỉ ẩn/hiện UI, không quyết định quyền.
- Transaction nằm ở use case cần atomicity, đặc biệt checkout, hủy đơn có hoàn tồn và nhập/xuất kho.
- Mọi lỗi chuẩn hóa thành application/problem+json với status, title, detail, instance và traceId.

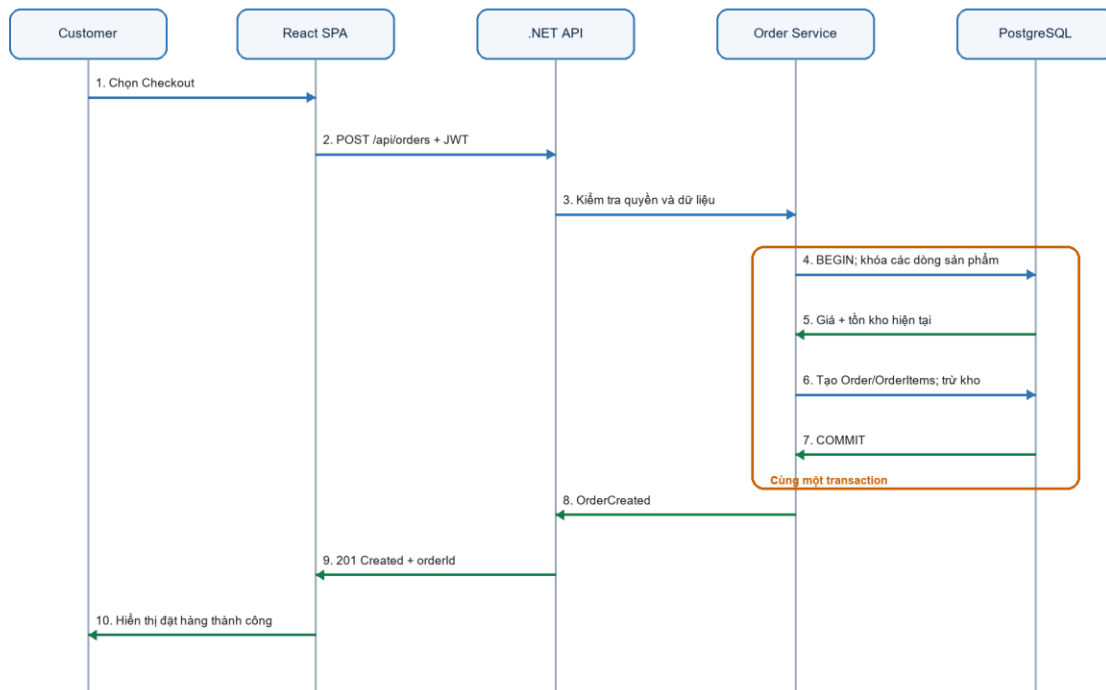
6.3. Luồng chính

Activity Diagram - đặt hàng



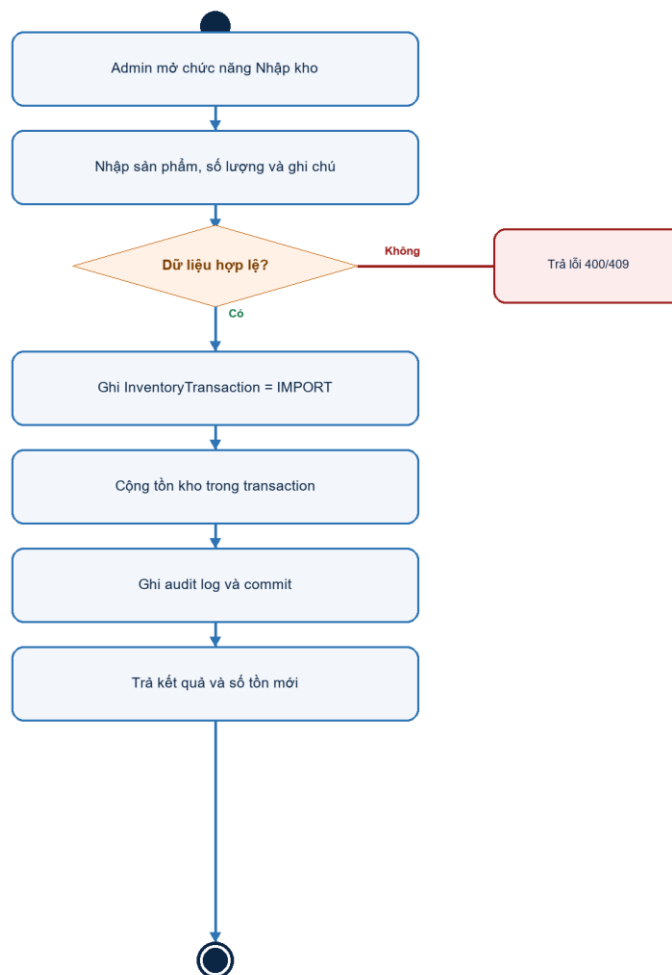
Hình 5. Activity Diagram - đặt hàng và các nhánh lỗi

Sequence Diagram - tạo đơn hàng



Hình 6. Sequence Diagram - checkout với transaction giá/tồn kho

Activity Diagram - nhập kho



Hình 7. Activity Diagram - nhập kho và audit

7. API CONTRACT

Quy ước: base URL /api; JSON UTF-8; thời gian ISO-8601 UTC; tiền là decimal; phân trang trả items, page, pageSize, totalItems, totalPages. Lỗi dùng RFC 7807 ProblemDetails mở rộng traceId và errorCode.

Method	Endpoint	Quyền	Mục đích	Status
POST	/auth/register	Public	Tạo Customer	201, 400, 409
POST	/auth/login	Public	Xác thực	200, 400, 401, 423
POST	/auth/refresh	Refresh cookie	Xoay token	200, 401
POST	/auth/logout	Authenticated	Thu hồi refresh token	204, 401
GET/PUT	/me	profile.self.*	Xem/cập nhật hồ sơ	200, 400, 401

Method	Endpoint	Quyền	Mục đích	Status
PUT	/me/password	Authenticated	Đổi mật khẩu	204, 400, 401
GET	/categories	Public	Danh mục hoạt động	200
GET	/products	Public	Search/filter/sort/page	200, 400
GET	/products/{id}	Public	Chi tiết sản phẩm	200, 404
POST/PUT	/admin/products/{id}	product.create/update	Tạo/sửa sản phẩm	200/201, 400, 403, 409
DELETE	/admin/products/{id}	product.delete	Ẩn/xóa mềm	204, 403, 404, 409
GET/PUT	/cart	cart.read/update	Lấy/cập nhật giỏ	200, 400, 401, 409
POST	/orders	order.create	Checkout	201, 400, 401, 403, 409
GET	/orders/me	order.self.read	Danh sách đơn của tôi	200, 401
GET	/orders/me/{id}	order.self.read + owner	Chi tiết đơn	200, 401, 403/404
POST	/orders/me/{id}/cancel	order.self.cancel + owner	Hủy đơn	204, 401, 403, 409
GET	/admin/orders	order.manage	Danh sách đơn	200, 403
PATCH	/admin/orders/{id}/status	order.manage	Chuyển trạng thái	200, 403, 404, 409
POST	/admin/inventory/imports	inventory.import	Nhập kho	201, 400, 403, 404
POST	/admin/inventory/exports	inventory.export	Xuất điều chỉnh	201, 400, 403, 409
GET	/admin/inventory/transactions	inventory.read	Lịch sử kho	200, 403
POST	/products/{id}/reviews	review.create	Đánh giá đã mua	201, 400, 403, 409
PATCH	/admin/reviews/{id}/status	review.moderate	Kiểm duyệt	200, 403, 404
GET	/admin/reports/overview	report.read	Dashboard theo khoảng ngày	200, 400, 403
PATCH	/admin/users/{id}/status	user.manage	Khóa/mở tài khoản	200, 403, 404, 409

7.1. Ví dụ contract tạo đơn

Request POST /api/orders { recipientName, phone, shippingAddress, paymentMethod, items:[{ productId, quantity }] }

201 Created { orderId, orderCode, status:"Pending", totalAmount, createdAt }

```
409 Conflict { type, title:"Business rule conflict", status:409, errorCode:"INSUFFICIENT_STOCK", detail,
traceld }
```

8. BUSINESS RULES VÀ STATE MACHINE

ID	Quy tắc
BR-01	Giá và tồn trên frontend chỉ mang tính hiển thị; backend luôn đọc lại khi checkout.
BR-02	OrderItem lưu snapshot tên/SKU/giá; thay đổi Product không làm đổi đơn cũ.
BR-03	Tồn kho không âm; cập nhật tồn và lịch sử kho trong cùng transaction.
BR-04	Customer chỉ đọc/hủy đơn thuộc user_id của mình.
BR-05	Chỉ đơn Pending được Customer hủy; Admin áp dụng chính sách hủy rõ ràng ở các trạng thái khác.
BR-06	Review cần OrderItem thuộc đơn Completed và mỗi OrderItem chỉ có một review của người mua.
BR-07	Xóa sản phẩm đã phát sinh giao dịch là xóa mềm/ẩn, không xóa vật lý.
BR-08	Doanh thu chỉ tính đơn Completed; đơn Cancelled không tính.
BR-09	Tài khoản LOCKED không thể login, refresh hoặc gọi endpoint được bảo vệ.
BR-10	Mọi thao tác Admin nhạy cảm phải có audit log.

8.1. Chuyển trạng thái đơn hợp lệ

Từ	Đến	Điều kiện/hành động
Pending	Confirmed	Admin xác nhận
Pending	Cancelled	Customer/Admin hủy
Confirmed	Preparing	Admin bắt đầu chuẩn bị
Confirmed	Cancelled	Admin hủy và hoàn tồn theo chính sách
Preparing	Shipping	Bàn giao vận chuyển
Shipping	Completed	Giao thành công

9. TRADE-OFF VÀ ARCHITECTURE DECISION RECORDS

ADR-001 - Modular monolith thay vì microservices

Context: Nhóm nhỏ, thời gian khoảng 6 tuần nhưng hệ thống có nhiều miền nghiệp vụ.

Options: A: một monolith không module; B: modular monolith; C: microservices.

Decision & rationale: Chọn B. Một Web API triển khai đơn giản, transaction checkout dễ quản lý; module rõ để giảm coupling.

Consequences: Lợi ích: ít hạ tầng, debug và test end-to-end dễ. Chi phí: scale theo từng module còn hạn chế.

Trigger xem xét lại: Xem xét microservices khi có nhiều đội độc lập, >500 request/giây bền vững hoặc module báo cáo gây nghẽn riêng.

ADR-002 - PostgreSQL thay vì MySQL

Context: Cần transaction, constraint, index và truy vấn báo cáo; nhóm đã có kinh nghiệm cả PostgreSQL/MySQL.

Options: A: PostgreSQL; B: MySQL; C: SQLite.

Decision & rationale: Chọn A vì constraint/transaction mạnh, kiểu dữ liệu và khả năng truy vấn báo cáo phù hợp; EF Core có provider ổn định.

Consequences: Chi phí: phải thống nhất provider/migration và không dùng cú pháp MySQL từ bài tuần 2.

Trigger xem xét lại: Xem xét lại nếu hạ tầng bắt buộc MySQL hoặc đội vận hành chỉ hỗ trợ MySQL.

ADR-003 - JWT ngắn hạn + refresh cookie HttpOnly

Context: SPA cần gọi API; giảm rủi ro token dài hạn bị lấy qua XSS.

Options: A: lưu JWT dài hạn ở localStorage; B: access JWT ngắn hạn trong memory + refresh HttpOnly; C: cookie session thuần.

Decision & rationale: Chọn B để đáp ứng yêu cầu JWT của rubric và hạn chế JavaScript đọc refresh token.

Consequences: Chi phí: cần CORS credentials, CSRF protection cho refresh/logout và cơ chế rotation/revocation.

Trigger xem xét lại: Xem xét cookie session thuần nếu frontend/backend cùng site và không còn ràng buộc JWT.

ADR-004 - Transaction + row lock cho tồn kho

Context: Hai khách có thể đặt sản phẩm cuối cùng đồng thời.

Options: A: tin số tồn từ frontend; B: optimistic concurrency; C: transaction với khóa dòng khi checkout.

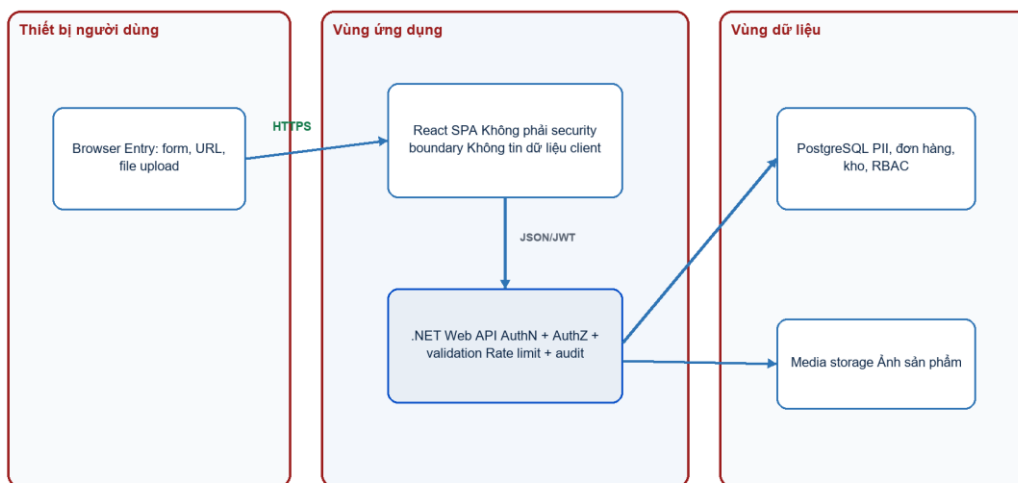
Decision & rationale: Chọn C cho phiên bản đầu vì logic rõ và bảo vệ invariant stock ≥ 0 ; kết hợp timeout ngắn.

Consequences: Chi phí: contention khi sản phẩm rất nóng; transaction phải ngắn và index đúng.

Trigger xem xét lại: Xem xét reservation/queue khi tỷ lệ conflict hoặc thời gian chờ lock vượt ngưỡng vận hành.

10. THREAT MODEL, RBAC VÀ JWT

Trust boundaries và entry points



Ranh giới đó: thay đổi mức tin cậy. Mọi yêu cầu qua ranh giới phải được xác thực, phân quyền và kiểm tra dữ liệu.

Hình 8. Entry point, trust boundary và vùng dữ liệu

10.1. Tài sản và mô hình đối thủ

Nhóm	Nội dung
Asset	Thông tin tài khoản/PII, password hash, token, giá/tồn, đơn hàng, quyền, báo cáo và audit log.
Entry point	Form đăng nhập/đăng ký, search/query, checkout, upload ảnh, endpoint Admin, refresh cookie.
Attacker	Guest ác ý, Customer cố truy cập chéo, tài khoản Admin bị chiếm, bot và người dùng nội bộ lạm quyền.
Trust boundary	Browser $\leftrightarrow$ Internet/API; API $\leftrightarrow$ Database; API $\leftrightarrow$ media storage; ranh giới Customer $\leftrightarrow$ Admin.

10.2. Threat register

ID	Threat	Risk	Mitigation	Test
T-01	Broken Object Level Authorization: đối orderId để xem đơn người khác	High	Kiểm tra owner trong service; query theo orderId + currentUserId; test cross-user	T-IDOR-01

ID	Threat	Risk	Mitigation	Test
T-02	Privilege escalation vào endpoint Admin	High	Permission policy, default deny, role/permission từ DB, audit	T-RBAC-01/02
T-03	Brute force/credential stuffing	High	Rate limit, lockout, password policy, log sự kiện	T-AUTH-03
T-04	Refresh/access token bị đánh cắp	High	Access 15 phút, refresh HttpOnly/Secure/SameSite, rotation, revoke	T-AUTH-04
T-05	Overselling do race condition	High	Transaction + row lock, stock constraint và test đồng thời	T-ORDER-03
T-06	Mass assignment sửa price/role/status	High	DTO allow-list; bỏ qua field server-owned; validation	T-API-01
T-07	Stored/reflected XSS qua tên/review	Medium	React escaping, sanitize nội dung cho phép, CSP	T-XSS-01
T-08	SQL injection	Medium	EF Core parameter hóa; không ghép raw SQL từ input	T-SQL-01
T-09	CSRF tại refresh/logout dùng cookie	Medium	SameSite, anti-forgery/header, kiểm tra Origin	T-CSRF-01
T-10	Upload ảnh độc hại/quá lớn	Medium	Allow-list MIME/đuôi, giới hạn kích thước, đổi tên, lưu ngoài web root	T-UPLOAD-01
T-11	Lộ PII/token qua log	High	Redact header/body nhạy cảm; structured log allow-list	T-LOG-01
T-12	Lạm dụng checkout/review	Medium	Rate limit, rule đã mua, idempotency key khi tạo đơn	T-BIZ-01

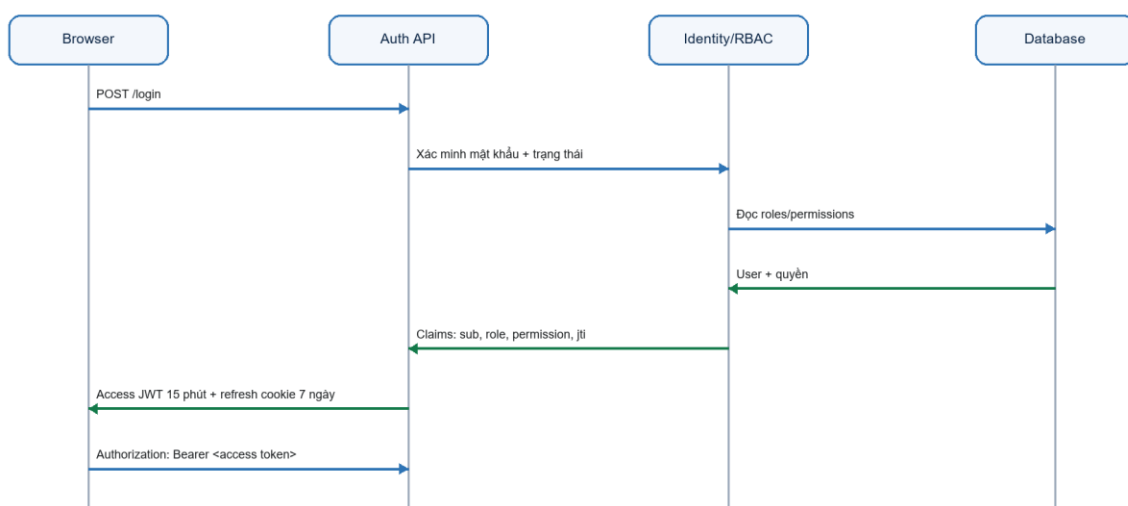
10.3. Ma trận Role-Permission

Permission	Guest	Customer	Admin
product.read / category.read / review.read	✓	✓	✓
auth.register / auth.login	✓	-	-
profile.self.* / cart.*	-	✓	-
order.create / order.self.read / order.self.cancel	-	✓	-
review.create	-	✓ có điều kiện đã mua	-
user.manage	-	-	✓
category.* / product.*	-	-	✓
inventory.read/import/export	-	-	✓
order.manage / review.moderate / report.read	-	-	✓

Nguyên tắc Backend default deny và least privilege. Ấn nút trên frontend chỉ cải thiện trải nghiệm; mọi quyết định quyền và quyền sở hữu resource phải được kiểm tra lại trong API/service.

10.4. JWT claims và vòng đời

JWT / Refresh Token flow



Hình 9. JWT access token và refresh token flow

Claim/thuộc tính	Giá trị/quy tắc
sub	user_id ổn định
email	Email chuẩn hóa; không dùng làm khóa sở hữu resource
role	Customer hoặc Admin; permission policy vẫn là kiểm tra chính
permission	Danh sách resource.action cần thiết hoặc nạp qua security stamp/cache ngắn
jti	Định danh access token phục vụ truy vết
iss / aud	Kiểm tra đúng issuer và audience
iat / nbf / exp	Access 15 phút; clock skew tối đa 1 phút
Refresh token	Random, lưu hash trong DB, HttpOnly Secure SameSite, 7 ngày, rotation và revoke

11. KẾ HOẠCH KIỂM THỬ

Test ID	Tình huống	Kết quả mong đợi
T-CAT-01	Tìm/loc/page catalog	200; dữ liệu và total đúng; p95 đạt NFR
T-AUTH-01	Đăng nhập sai mật khẩu	401, không cấp token
T-AUTH-03	Đăng nhập lặp vượt ngưỡng	429/lockout và security log
T-RBAC-01	Customer gọi /admin/products	403, không thay đổi dữ liệu

Test ID	Tình huống	Kết quả mong đợi
T-RBAC-02	Không JWT gọi endpoint bảo vệ	401, không redirect HTML
T-IDOR-01	Customer A đọc đơn Customer B	403/404, không lộ PII
T-ORDER-01	Đặt hàng đủ tồn	201; Order/Items/InventoryTxn nhất quán
T-ORDER-02	Đặt vượt tồn	409; rollback; stock không đổi
T-ORDER-03	Hai request tranh sản phẩm cuối	Chỉ một request thành công; stock không âm
T-ORDER-04	Chuyển sai trạng thái	409 và audit không ghi transition thành công
T-REV-01	Review khi chưa mua	403
T-REV-02	Review sau đơn Completed	201 và hiển thị sau moderation policy
T-INV-01	Nhập kho hợp lệ	201; tồn tăng; có InventoryTxn/AuditLog
T-API-01	Body chứa price/role server-owned	Bỏ qua hoặc 400; không mass assignment
T-XSS-01	Review chứa script	Không thực thi trong UI; nội dung được xử lý
T-PERF-01	50 VU đọc catalog 10.000 SP	p95 ≤ 2s, error rate <1%
T-OPS-01	DB không sẵn sàng	/health/live vẫn live; /health/ready unhealthy

12. TRACEABILITY MATRIX

Goal	UC	US/AC	FR/NFR	Entity	API	Component	Test
G-01	UC-01	US-01 / AC-01	FR-CAT-01..03; NFR-PERF-01	Category, Product	GET /products	Catalog	T-CAT-01
G-02	UC-04	US-02 / AC-02,03	FR-ORDER-01,02; NFR-DATA-01	Order, OrderItem, Product, InventoryTxn	POST /orders	Orders+Inventory	T-ORDER-01..03
G-03	UC-05	US-03,04 / AC-04,05	FR-ORDER-03	Order	GET/POST /orders/me	Orders	T-IDOR-01
G-03	UC-06	US-05 / AC-06	FR-REV-01,02	Review, OrderItem	POST /products/{id}/reviews	Reviews	T-REV-01,02
G-04	UC-07	US-06	FR-CAT-03; FR-RBAC-01	Product, Category	/admin/products	Catalog	T-RBAC-01
G-05	UC-08	US-07 / AC-07	FR-INV-01,02; NFR-DATA-01	Product, InventoryTxn, AuditLog	/admin/inventory/*	Inventory	T-INV-01
G-04	UC-09	US-08 / AC-08	FR-ORDER-04	Order, AuditLog	PATCH /admin/orders/{id}/status	Orders	T-ORDER-04
G-04	UC-10	US-09 / AC-09	FR-AUTH-02; FR-RBAC-01,02	User, Role, Permission	PATCH /admin/users/{id}/status	Identity	T-AUTH-01,03
G-06	UC-11	US-10 / AC-10	FR-REPORT-01; NFR-PERF-01	Order, OrderItem, Product	GET /admin/reports/overview	Reporting	T-PERF-01
G-04	UC-02	AC-04,09	NFR-SEC-01,02	RefreshToken, AuditLog	/auth/*	Identity/RBAC	T-RBAC-02; T-AUTH-03

13. KHẢ NĂNG MỞ RỘNG VÀ VẬN HÀNH

13.1. Giả định tải và bottleneck

Giả định	Thiết kế hiện tại	Trigger nâng cấp
≤10.000 sản phẩm; 50 VU đọc	Index category/status/price; pagination; projection DTO	p95 catalog >2s trong 15 phút
≤200 đơn/ngày trong đồ án	Transaction ngắn + row lock	Lock wait/conflict >2% checkout
Dashboard theo ngày/tháng	Query tổng hợp có index, cache in-memory 60s	Báo cáo chiếm >30% DB CPU
Ảnh sản phẩm vừa phải	Lưu file ngoài DB, DB chỉ giữ URL/metadata	Bảng thông hoặc dung lượng vượt máy chủ

13.2. Error handling, health và log

- Global exception handler trả ProblemDetails; lỗi validation 400, auth 401, forbidden 403, not found 404, conflict nghiệp vụ 409.
- Correlation/trace ID truyền từ frontend hoặc tạo ở API, xuất hiện trong response lỗi và structured log.
- Health checks tách live/ready; readiness kiểm tra PostgreSQL và dependency bắt buộc.
- Audit log append-only cho quyền, tài khoản, kho, sản phẩm và trạng thái đơn; không ghi password/token/PII không cần thiết.
- Backup hằng ngày; kiểm thử restore và ghi RPO/RTO thực tế trước khi triển khai thật.

13.3. Technical debt và roadmap

Mốc	Nội dung
V1 - 6 tuần	Modular monolith; COD/giả lập; một kho; search DB; UI responsive; đầy đủ RBAC/audit cốt lõi.
V1.1	Email thông báo, tối ưu ảnh, cache catalog, cải thiện test tự động và dashboard.
V2	Build PC/compatibility, voucher, cổng thanh toán và vận chuyển thật sau khi threat model/API được cập nhật.
Khi tải tăng	Redis cache, background jobs, read model báo cáo hoặc tách service có số liệu chứng minh bottleneck.

13.4. Kế hoạch triển khai 6 tuần

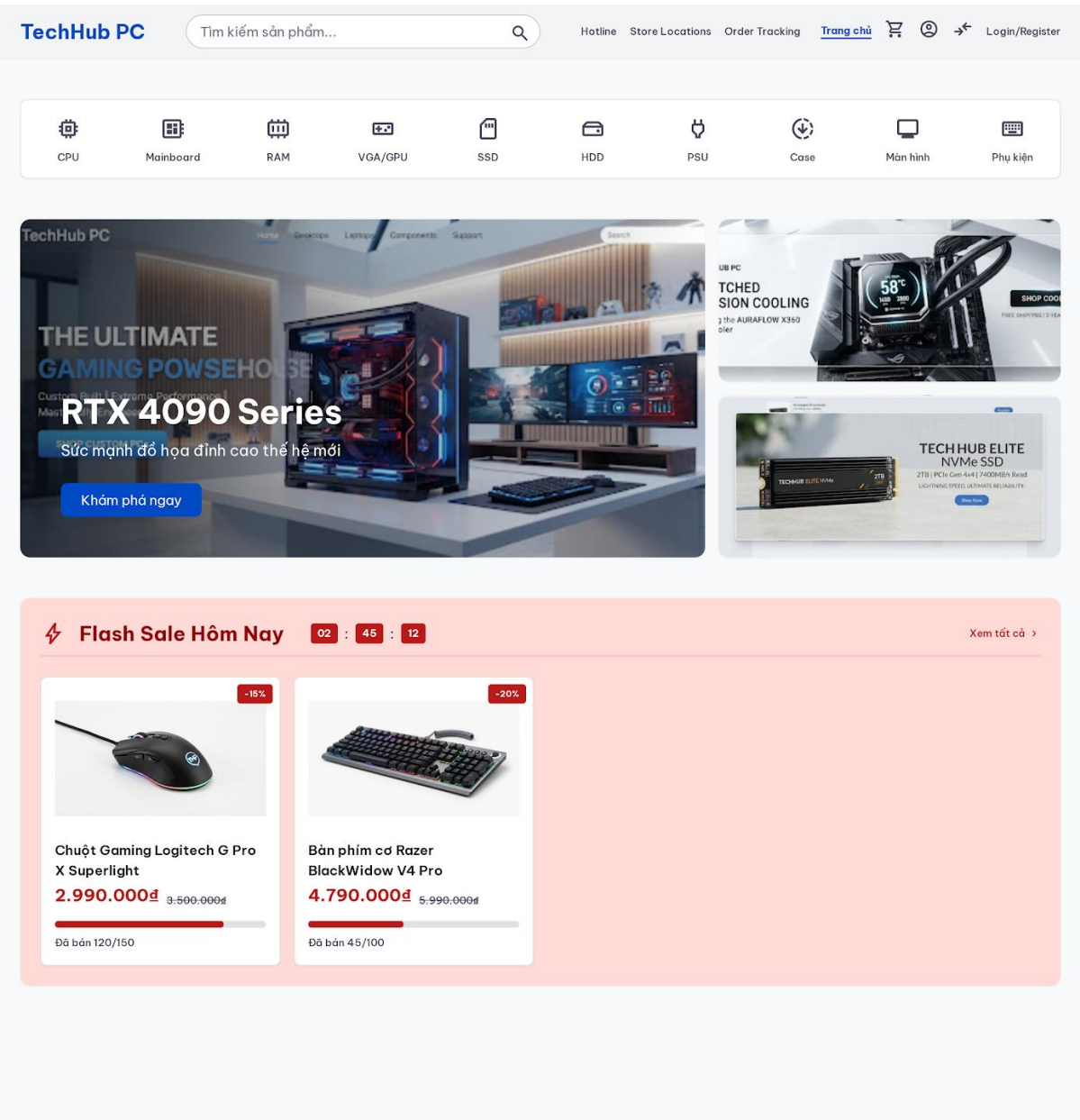
Thời gian	Kết quả cần đạt
Tuần 1	Chốt FR/NFR, ERD, API, ADR và RBAC; tạo migration nền.
Tuần 2	Identity/RBAC/JWT; catalog và Admin sản phẩm/danh mục.
Tuần 3	Frontend store: home, listing, detail, auth, cart.

Thời gian	Kết quả cần đạt
Tuần 4	Checkout, orders, state machine và inventory transaction.
Tuần 5	Reviews, admin users/orders/inventory/reports; negative authorization tests.
Tuần 6	Tích hợp, performance/security test, sửa lỗi, README, minh chứng và demo.

14. THIẾT KẾ GIAO DIỆN VÀ ÁNH XẠ CHỨC NĂNG

Bộ giao diện Stitch là design reference. Khi triển khai, mỗi màn hình được dựng lại bằng React component, route và dữ liệu API; file HTML xuất từ Stitch không được dùng làm production source hoặc commit vào repository.

Màn hình	Route	Use Case	Component chính
Trang chủ	/	UC-01	Header, CategoryNav, HeroBanner, ProductSection, Footer
Danh sách sản phẩm	/products	UC-01	FilterSidebar, SortBar, ProductGrid, Pagination
Chi tiết sản phẩm	/products/:id	UC-01,03,06	Gallery, PriceStock, Specs, Reviews, RelatedProducts
Giỏ hàng	/cart	UC-03	CartItem, QuantityControl, OrderSummary
Thanh toán	/checkout	UC-04	ShippingForm, PaymentSelector, CheckoutSummary
Tài khoản/đơn	/account/*	UC-05,06	ProfileForm, OrderList, OrderTimeline, ReviewForm
Admin	/admin/*	UC-07..11	AdminLayout, DataTable, StatusBadge, FormModal, Dashboard



Hình 10. Thiết kế tham chiếu trang chủ TechHub PC

TechHub PC

Premium Hardware Store

CPU

Mainboard

RAM

VGA/GPU

SSD

HDD

PSU

Case

Màn hình

Phụ kiện

Hotline

Store Locations

Order Tracking

Login/Register

ASUS ROG Strix GeForce RTX 4080 SUPER 16GB GDDR6X

☆ ☆ ☆ ☆ ☆

(42 đánh giá)

29.990.000 đ

35.290.000 đ

Còn hàng (Sẵn sàng giao)

Số lượng

-

1

+

Thêm vào giỏ

Bảo hành chính hãng 36 tháng

Miễn phí giao hàng toàn quốc

Đổi trả trong 15 ngày nếu lỗi nhà sản xuất

Thông số kỹ thuật

Mô tả sản phẩm

Nhà sản xuất	ASUS
GPU	NVIDIA GeForce RTX 4080 SUPER
Bộ nhớ	16GB GDDR6X
Bus bộ nhớ	256-bit
Cổng giao tiếp	2x HDMI 2.1a, 3x DisplayPort 1.4a
Nguồn để xuất	850W

Trang bị sức mạnh vượt trội từ kiến trúc NVIDIA Ada Lovelace, ASUS ROG Strix GeForce RTX 4080 SUPER mang đến trải nghiệm gaming và sáng tạo không giới hạn.

Hệ thống tản nhiệt được nâng cấp với quạt Axial-tech lớn hơn, buồng hơi (vapor chamber) được thiết kế lại tối ưu luồng khí, đảm bảo nhiệt độ luôn lý tưởng ngay cả khi tải nặng.

Thiết kế khung kim loại chắc chắn cùng dải đèn ARGB tùy chỉnh qua Aura Sync tạo nên vẻ ngoài đậm chất game thủ, phù hợp cho mọi bộ PC cao cấp.

Sản phẩm tương tự

GIGABYTE GeForce RTX 4070 Ti SUPER GAMING...

23.590.000 đ

MSI GeForce RTX 4090 SUPRIM X 24G

55.990.000 đ

TechHub PC

© 2024 TechHub PC. Tất cả quyền được bảo lưu.

Chính sách bảo hành

Hướng dẫn thanh toán

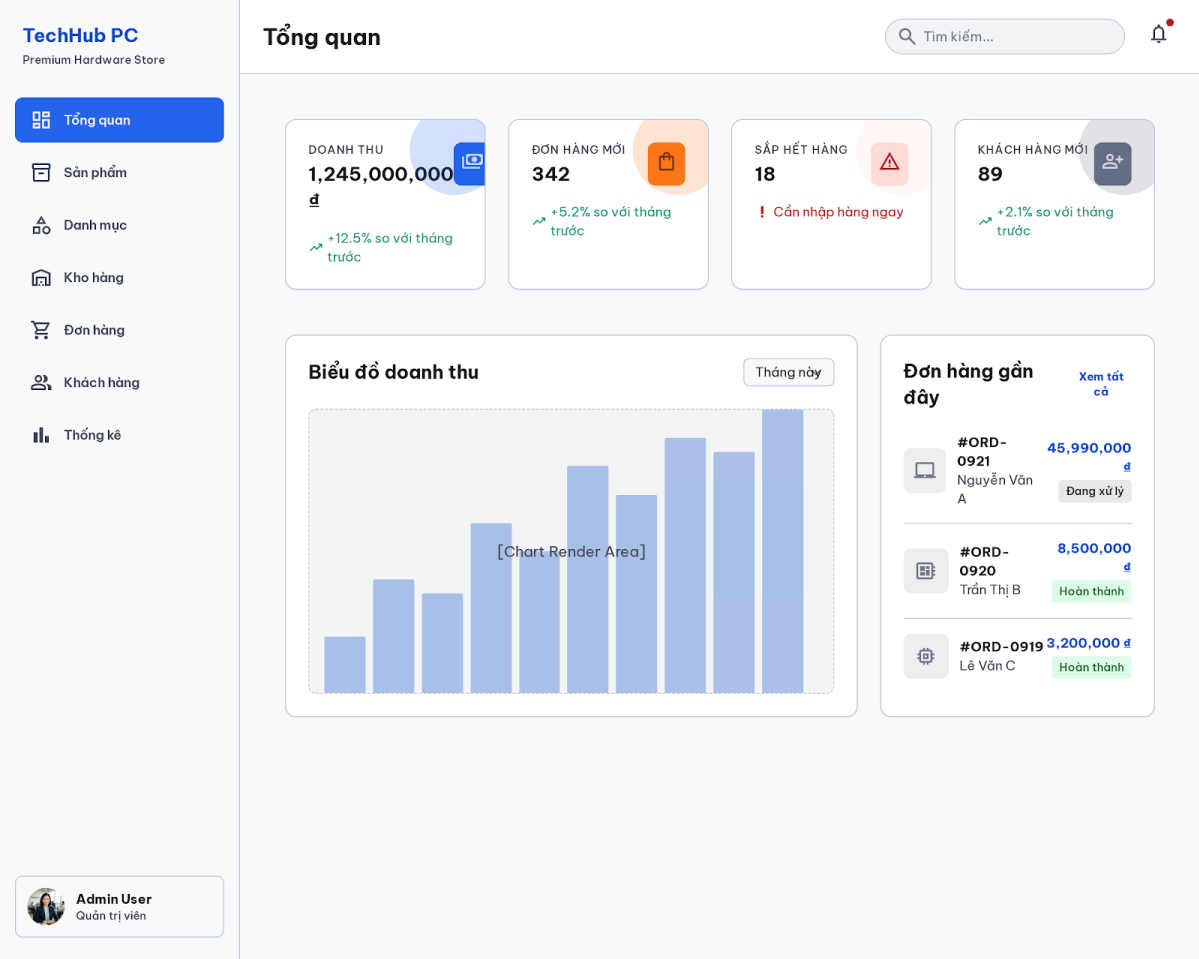
Tuyển dụng

Vấn chuyển

Liên hệ

Hình 11. Thiết kế tham chiếu trang chi tiết sản phẩm

Trang 29



Hình 12. Thiết kế tham chiếu dashboard quản trị

TechHub PC

Quản trị kho

Admin

Quản lý Kho Hàng

Theo dõi và quản lý số lượng tồn kho sản phẩm.

Xuất kho

Nhập kho

TỔNG SẢN PHẨM

1,245

CẢNH BÁO SẮP HẾT

12

VỪA NHẬP HÔM NAY

45

Mức Tồn Kho Hiện Tại

Q

Tìm SKU, tên sản phẩm...

SKU	TÊN SẢN PHẨM	TỒN KHO HIỆN TẠI	TRẠNG THÁI / CẢNH BÁO	HÀNH ĐỘNG
CPU-I9-14900K	Intel Core i9-14900K	145	ĐỦ HÀNG	
VGA-RTX-4090-ROG	ASUS ROG Strix RTX 4090 OC 24GB	2	SẮP HẾT	
MB-Z790-AORUS	Gigabyte Z790 AORUS MASTER	0	HẾT HÀNG	
RAM-D5-6000-32G	Corsair Vengeance RGB 32GB (2x16GB) DDR5 6000MHz	89	ĐỦ HÀNG	

Lịch Sử Biến Động Kho

THỜI GIAN	MÃ GD	LOẠI	SẢN PHẨM (SKU)	SỐ LƯỢNG	NGƯỜI THỰC HIỆN
24/10/2023 14:30	TXN-88912	Xuất kho	Intel Core i9-14900K (CPU-I9-14900K)	-5	admin_nv1
24/10/2023 10:15	TXN-88911	Nhập kho	Corsair Vengeance RGB 32GB (RAM-D5-6000-32G)	+50	kho_manager
23/10/2023 16:45	TXN-88910	Xuất kho	ASUS ROG Strix RTX 4090 (VGA-RTX-4090-ROG)	-1	admin_nv2

Hình 13. Thiết kế tham chiếu quản lý kho

15. KẾT LUẬN

Thiết kế TechHub PC đã xác định rõ mục tiêu, tác nhân, luồng nghiệp vụ, dữ liệu, API, phân quyền, rủi ro và tiêu chí kiểm thử. Kiến trúc modular monolith cân bằng giữa khả năng hoàn thành trong phạm vi đề án và khả năng mở rộng có điều kiện. Trọng tâm triển khai tiếp theo là hoàn thành frontend theo component/route, sau đó xây backend .NET 10 và kết nối PostgreSQL theo contract trong tài liệu.

Điểm kiểm soát trước khi nộp Điền lớp, nhóm/sinh viên và giảng viên trên bìa; cập nhật mục lục trong Word; đổi tên file theo TenLop_TenNhom_TenDeTai; kiểm tra repository không chứa demo_template, .env, mật khẩu hoặc API key.

TÀI LIỆU THAM KHẢO VÀ CÔNG CỤ

- Rubric_Phan_tich_Thiet_ke_HTTP.docx do giảng viên cung cấp.
- Website_Thuong_mai_Dien_tu_Linh_kien_May_tinh.docx - mô tả đề tài ban đầu.
- Microsoft Learn - ASP.NET Core 10 authentication và policy-based authorization:
<https://learn.microsoft.com/aspnet/core/security/authentication/> và
<https://learn.microsoft.com/aspnet/core/security/authorization/policies>
- RFC 7519 - JSON Web Token (JWT): <https://www.rfc-editor.org/rfc/rfc7519>
- OWASP API Security Top 10 - 2023: <https://owasp.org/API-Security/editions/2023/en/0x11-t10/>
- PostgreSQL Documentation - Explicit Locking: <https://www.postgresql.org/docs/current/explicit-locking.html>
- Bộ thiết kế TechHub PC xuất từ Stitch, chỉ dùng làm reference cho UI.

Công cụ và công khai việc sử dụng AI

Công cụ sử dụng gồm Microsoft Word/DOCX, React/Vite, ASP.NET Core, PostgreSQL, Swagger/Postman, Git/GitHub và Stitch. ChatGPT/Codex được dùng để hỗ trợ cấu trúc, rà soát tính nhất quán, sinh bản nháp tài liệu và kiểm tra trình bày. Người thực hiện chịu trách nhiệm đọc lại, hiệu chỉnh, triển khai, kiểm thử và giải thích toàn bộ quyết định trong buổi bảo vệ.

PHỤ LỤC A - GLOSSARY

Thuật ngữ	Giải thích
Authentication (AuthN)	Xác định người dùng là ai.
Authorization (AuthZ)	Xác định người dùng được phép làm gì trên resource cụ thể.
RBAC	Phân quyền dựa trên role; trong thiết kế này role gom các permission resource.action.
JWT	Token chứa claims được ký; không phải nơi lưu bí mật và phải kiểm tra issuer/audience/expiry.
Snapshot	Bản sao tên/giá/địa chỉ lưu trên đơn để bảo toàn lịch sử.
Default deny	Không có quyền rõ ràng thì từ chối truy cập.
Idempotency	Gửi lại cùng yêu cầu không tạo hiệu ứng trùng lặp ngoài dự kiến.
ProblemDetails	Định dạng lỗi HTTP chuẩn gồm type, title, status, detail, instance và trường mở rộng.